A Secure Authentication Mechanism for Federated Metaverses Using Non-Fungible Tokens (NFTs)

Mohammed Shakib Hossain*, Khawaja Ehsun Ul Hawak*, Mutasin Jawad*, Md Yeasin Ali*, Sagar Karmoker*, Masum Alam Nahid†, Hossain Shahriar‡ and Md Sadek Ferdous*
*Department of Computer Science and Engineering, BRAC University, Dhaka, Bangladesh
†Cryptic Consultancy Limited, London, UK
‡Center for Cybersecurity, University of West Florida, FL, USA
Email: {mohammed.shakib.hossain, ehsun.ul.hawak, mutasin.jawad}@g.bracu.ac.bd, yeasin.ali@bracu.ac.bd, sagarkarmoker.official@gmail.com, masum@cryptic-consultancy.co.uk, hshahriar@uwf.edu, sadek.ferdous@bracu.ac.bd

***Abstract*—The rapid growth of consumer-grade augmented reality (AR) and virtual reality (VR) devices has driven the interest in metaverses, a type of fully immersive virtual world for interaction, services, and digital commerce, where secure and decentralized authentication is essential. Traditional password-based and centralized authentication mechanisms suffer from credential theft, identity fragmentation, and single points of failure, making them unsuitable for interoperable metaverse environments. This paper proposes a blockchain-based authentication framework that represents user identities as non-transferable, soulbound-style NFTs (Non-Fungible Tokens) cryptographically bound to user wallets, enabling passwordless and verifiable authentication without reusable credentials. The framework further supports cross-metaverse authentication through a decentralized Circle of Trust (CoT), where autonomous metaverses recognize identity NFTs issued by trusted peers under on-chain governance. We present the system's architecture based on a rigorous threat model, formal protocol specification and validation, an implemented proof-of-concept integrated with a VR metaverse, security analysis, and a user study. The results provide initial evidence that the proposed approach supports secure, interoperable, and usable authentication for both standalone and federated metaverse environments.**

***Index Terms*—Blockchain, Smart contract, Non-Fungible Token (NFT), Authentication, Metaverse, Federated Metaverse**

I. Introduction

The *Metaverse* denotes an immersive shared online environment that integrates persistent virtual spaces, digitally augmented representations of the physical world, and augmented reality experiences, enabling users to interact, socialize, and engage in economic activities across independently operated virtual worlds [11]. With increasing adoption across domains, it is projected to contribute nearly USD 3 trillion to global GDP by 2031 [7].

Metaverse platforms require scalable and secure authentication, yet current systems largely rely on usernames and passwords, biometrics, two-factor authentication (2FA), OAuth-based logins, and session tokens [27], [43]. These mechanisms exhibit well-known security and usability limitations, including exposure to phishing, brute-force attacks, credential theft, session hijacking, and biometric privacy risks [15], [24]. Moreover, fragmented authentication schemes across platforms increase user burden, while OAuth-based solutions introduce centralized trust dependencies that conflict with the decentralized goals of the Metaverse [45].

Blockchain, particularly Ethereum and other EVM-compatible platforms, offers an alternative by enabling cryptographically verifiable, decentralized authentication primitives [26], [46]. Additionally, NFT-based authentication enables reliable identity verification within individual platforms, but emerging metaverse ecosystems increasingly require interoperability across autonomous platforms. Isolated identity systems hinder seamless cross-metaverse access, motivating a federated metaverse model that enables cross-platform authentication without duplicating identities [33]. Federated Identity Management (FIM) allows users authenticated by an Identity Provider (IdP) to access services offered by Service Providers (SPs) within a Circle of Trust (CoT) [14]. However, conventional FIM architectures rely on centralized federation operators and static metadata registries, limiting scalability and introducing single points of failure, which blockchain-based federation governance [1], [37] addresses only for conventional digital identities rather than NFT-bound credentials.

Unlike existing NFT-based authentication approaches that primarily target identity verification within a single platform, interoperable authentication across independently operated metaverse platforms requires coordinated trust management, credential lifecycle control, and decentralized governance [33]. Prior blockchain-based federation-governance systems address decentralized trust management for conventional digital identities, but do not bind credentials to wallet-verifiable, non-transferable NFTs, nor do they combine this with formal protocol verification and an implemented, user-evaluated system [1], [37]. Meanwhile, many decentralized identity systems expose identity attributes directly or rely on issuer-controlled revocation, limiting privacy guarantees and introducing additional trust dependencies [37]. To our knowledge, no prior work jointly addresses privacy-aware NFT-bound credentials, decentralized federation governance, and formal, user-evaluated validation within a single framework.

In this paper, we propose a secure authentication mechanism for federated metaverses leveraging NFT-based identity

credentials bringing the following contributions:

- We present a secure architecture and proof-of-concept (PoC) federated authentication framework enabling cross-metaverse interoperability through a decentralized Circle of Trust (CoT), where trust is managed via on-chain governance rather than centralized federation operators.
- We incorporate privacy-aware identity representation and issuance–revocation lifecycle control, using cryptographic commitments for sensitive attributes, wallet-bound non-transferable identity tokens, and user-initiated on-chain revocation via smart-contract–enforced burn operations.
- We define multiple authentication use-cases and associated cryptographic protocol flows to demonstrate the applicability of the proposed system.
- We evaluate usability through a user study conducted on the implemented PoC.
- We formally verify the protocols using a state-of-the-art tool *ProVerif* [4]

II. Related Work

Several studies have explored NFTs, decentralized identities, and blockchain-based mechanisms for authentication and identity management. Hong et al. [16] propose a blockchain-based biometric framework that stores Electrooculography (EOG) data as NFTs to improve decentralization and forgery resistance. Banaeian et al. [2] present an NFT-based identity management concept for metaverses, while Kim et al. [20] combine decentralized identifiers (DIDs), Soulbound Tokens (SBTs), and zero-knowledge proofs to support privacy-preserving avatar authentication. More recently, Madhwal et al. [22] introduce a blockchain-based access control architecture using non-transferable NFTs and gas-efficient IPFS URI management for tiered content access. Although these works are relevant, they mainly address identity management or access control within a single platform and do not consider federated authentication, decentralized governance, or cross-metaverse trust establishment.

Other studies focus on authentication protocols and security architectures for metaverse environments. Manzoor et al. [25] combine NFTs with Proof-of-Stake consensus to improve authenticity and scalability, but provide limited details on user authentication. Ryu et al. [35] propose a formally verified mutual authentication protocol; however, the design relies on a permissioned blockchain and partially centralized registration. Similarly, Khan et al. [19] integrate certificate authorities into NFT-based authentication, which reintroduces centralized trust dependencies. Elazzaoui et al. [9] present a post-quantum NFT framework for protecting virtual asset ownership, but do not address authentication or implementation. Stephenson et al. [39] survey authentication mechanisms for AR/VR and metaverse systems and highlight the continued reliance on passwords and PINs while advocating privacy-preserving and usable authentication mechanisms.

Collectively, existing works are largely conceptual [2], domain-specific [16], [40], or dependent on centralized trust infrastructures [19], [35]. Although recent studies have advanced NFT-based identity and access management [20], [22], they rarely combine threat modelling, protocol specification, implementation, formal verification, and usability evaluation within a unified framework. Furthermore, existing solutions predominantly target standalone platforms, leaving decentralized trust establishment, federation governance, credential lifecycle management, and interoperable authentication across autonomous metaverse platforms insufficiently explored.

This work proposes and implements a CA-independent federated NFT-based authentication framework integrating decentralized governance, privacy-aware identity representation, credential issuance and revocation, formal protocol verification, and a proof-of-concept implementation. The framework enables interoperable authentication across autonomous metaverse platforms through decentralized trust management while preserving the autonomy of individual platforms.

III. Architecture and Implementation

This section outlines the system threats, architecture and its implementation.

A. Threat model, attacker capabilities and security requirements

A threat model helps identify potential security issues early, strengthening system design [36]. We employ the widely used STRIDE model [36], along with replay attacks, a critical threat in authentication, as summarized in Table I.

We define the adversary's capabilities as: (i) *network control* – eavesdropping, intercepting, modifying, or replaying messages over public channels (HTTPS, JSON-RPC); (ii) *blockchain access* – reading all on-chain data (transactions, NFT metadata, contract state, event logs) and submitting legitimate transactions; (iii) *resource exhaustion* – flooding the system with requests; (iv) *governance manipulation* – compromising up to 1/4 of federation members, below the 75% supermajority threshold, permitting influence but not unilateral control; and (v) *cryptographic limits* – the adversary cannot break ECDSA, hash functions, or TLS, nor forge signatures without the corresponding private key. Table I presents the security requirements that mitigate each threat.

B. Architecture

Figure 1 presents the architecture of the proposed system, comprising four entities: *Users*, *User Wallets*, the *Metaverse Platform*, and blockchain *Smart Contracts*. Users interact with a metaverse through a client interface, while authentication and blockchain interactions are mediated by a cryptographic wallet (e.g., MetaMask) that securely manages private keys and generates digital signatures, verifying credential ownership without private key disclosure. Each metaverse operates backend services that communicate with on-chain smart contracts for credential issuance, verification, and revocation (Section IV).

Since credentials must be uniquely bound to a user, identity tokens are non-transferable by design, disabling ERC-721

TABLE I: Security threats and requirements

Threats (T)	Security Requirements (SR)
(T1) Spoofing: Attackers falsify data such as tokens to impersonate users for unauthorized access.	**SR1:** An adversary without the user's private key cannot authenticate. Identity NFTs must be cryptographically bound to wallet ownership.
(T2) Tampering: Adversaries may alter tokens, NFT metadata, or ownership records in transit or at rest.	**SR2:** NFT metadata, ownership records, and issuer signatures must be tamper-evident. Any modification must be detectable.
(T3) Repudiation: Users may deny actions or transactions, and the system cannot prove otherwise.	**SR3:** User authentication and credential issuance must utilize cryptographic ownership verification.
(T4) Information Disclosure: Unauthorized exposure of sensitive user data to individuals or systems.	**SR4:** Sensitive user attributes (e.g., email) must not be stored in plaintext on-chain (only hiding commitments) and must be transmitted over a secure channel.
(T5) Denial of Service (DoS): An adversary can overload metaverse services to render them unavailable.	**SR5:** Authentication should not require unbounded resources, and network flooding should not asymmetrically benefit an adversary.
(T6) Elevation of Privilege: Attackers gain higher access rights, performing unauthorized actions.	**SR6:** Compromised or obsolete NFTs must be invalidated and their status verifiable by all metaverses.
(T7) Replay Attack: Attackers reuse previous transactions or data.	**SR7:** Fresh nonces or timestamps must bind each protocol run.

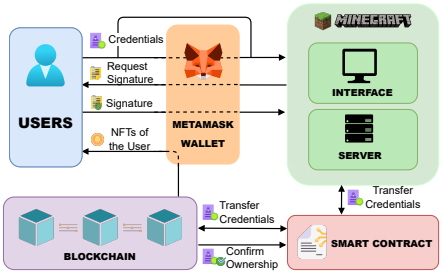


Fig. 1: Architecture of the proposed system

transfer functionality following soulbound token proposals such as EIP-5192 [10], [6], while retaining ERC-721 compatibility. This enables immutable, verifiable ownership-based authentication without reusable shared secrets [21]. Sensitive identity attributes (e.g., email addresses) are not stored in plaintext on-chain; instead, cryptographic commitments preserve privacy.

Additionally, the architecture extends to a federated trust model to enable cross-metaverse authentication (Figure 2). Autonomous metaverse platforms join a federation to form a Circle of Trust (CoT), where credential-issuing metaverses function as Identity Providers (IdPs) while service-providing metaverses act as Service Providers (SPs). The federation membership, governance proposals (e.g., quorum updates), and member admission or revocation are managed through a dedicated governance smart contract that enforces proposal submission and democratic voting, ensuring transparent, auditable, and decentralized federation management with fine-grained access control. However, federation membership does not imply universal trust among the participating metaverses. Each metaverse platform maintains an independent local trust registry to selectively accept credentials from trusted issuers, thereby preventing compromised or untrusted members from

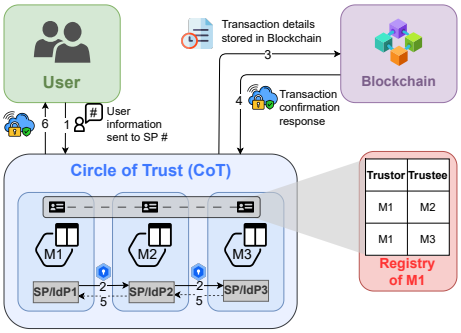


Fig. 2: Circle of Trust in Metaverse Identity Federation

automatically affecting all participants.

C. Implementation

The proposed system is implemented on a Minecraft Paper server [32], where gameplay is accessible only after successful NFT-based authentication. The frontend and backend use Next.js [41] and Node.js [30], with blockchain interactions handled via wagmi v2.14.8 [42] and web3.js v4.11.0 [44]. Smart contracts follow the ERC-721 standard, implemented in Solidity v0.8.22 [13] and deployed on Ethereum [12]. Registration, minting, and authentication use ECDSA challenge–response signatures [18], verified on-chain via OpenZeppelin's *SignatureChecker* [31]. SparkJava v2.9.3 [38] handles Minecraft server–frontend communication, while a web3.js middleware provides low-latency blockchain interaction.

IV. Protocol Flow and Use-case

This section presents the system protocol and its operation: the data model (Table II) defines the data shared across use-cases, Section IV-A describes the key algorithms, and Sections IV-B1, IV-B2, and IV-B3 present the complete protocol flows.

TABLE II: Data Model

$\text{registerReq} \triangleq (\text{credentials})$, $\text{credentials} \triangleq (\text{ec}, \text{name}, \text{Addr}_U)$
$\text{serviceReq} \triangleq (UUID_U)$, $\text{serviceRes} \triangleq (\text{access,/reject})$, $\text{registerRes} \triangleq (\text{SignedCredentials}^U_{MV})$, $\text{SignedCredentials}^U_{MV} \triangleq (\{\text{credentials}\}_{K^{-1}_{MV}})$
$\text{NFTMintReq} \triangleq (\text{credentials}, \text{SignedCredentials}^U_{MV})$, $\text{NFTMintRes} \triangleq (\text{Confirmation message})$, $\text{NFT}^U_{MV} \triangleq (\text{TokenId}_{NFT^U_{MV}}, \text{name}, \text{ec}, \text{K}_{MV})$
$\text{WalletAddressReq} \triangleq (\text{MetaMask prompt})$, $\text{WalletAddressRes} \triangleq (\text{Addr}_U)$, $\text{NFTReq} \triangleq (\text{Addr}_U)$, $\text{NFTRes} \triangleq (\text{NFTs}^U_{MV})$, $\text{SignatureReq} \triangleq (\text{challenge})$, $\text{SignatureRes} \triangleq (\sigma_U)$, $\text{Metaverse} \triangleq (\text{Addr}_M, \text{websiteUrl}, \text{joinedAt})$
$\text{NFTMetadataReq} \triangleq (\text{TokenId}_{NFT^U_{MV}})$, $\text{NFTMetadataRes} \triangleq (\text{TokenId}_{NFT^U_{MV}}, \text{name}, \text{ec}, \text{K}_{MV})$, $\text{membershipVote} \triangleq (\text{candidateAddr} \in \text{Addr}_M, v \in \{0,1\})$, $\text{votingStatus} \triangleq \{\text{Active}, \text{Expired}, \text{Approved}, \text{Rejected}\}$
$\text{membershipReq} \triangleq (\text{websiteUrl})$, $\text{membershipRes} \triangleq (\text{votingStatus}, v)$
$\text{governanceProposalReq} \triangleq (q_{new}, \text{desc})$, $\text{governanceVote} \triangleq (GP_i, v \in \{0,1\})$, $\text{governanceProposalRes} \triangleq (GP_i, \text{votingStatus}, \textit{executed} \in \{0,1\})$
$\textit{GovernanceProposal} \triangleq (\text{Addr}_M, \text{Type}_{Quorum}, q_{new}, t_0, \textit{executed} \in \{0,1\}, \textit{desc}, \textit{VoteDetails})$, $\text{Type}_{Quorum} \triangleq \{1 : \text{QuorumChange}, 2 : \text{MemberRemoval}\}$
$\textit{VoteDetails} \triangleq (\text{candidateAddr} \in \text{Addr}_M, \text{websiteUrl}, \textit{yesVotes} \in \mathbb{Z}^+, \textit{noVotes} \in \mathbb{Z}^+, \textit{expiresAt}, \textit{voters}[], \textit{hasVoted}[\text{Addr}_M])$

A. Algorithm

Algorithm 1 SafeMint for Soulbound NFT Authentication

Require: $Addr_U$, $name$, ec, σ_{MV}
Ensure: Soulbound identity NFT NFT^U_{MV}
$h \leftarrow \mathsf{Keccak256}(Addr_U \parallel name \parallel ec)$
$m \leftarrow \mathsf{EthSign}(h)$
$recover \leftarrow \mathsf{ECDSARecover}(m, \sigma_{MV})$
if $\exists NFT \in SC_{Token} : owner(NFT) = Addr_U$ **then**
  return Abort
end if
if $recover \neq K_{MV}$ **then**
  return Abort
end if
$TokenId_{NFT^U_{MV}} \leftarrow \mathsf{NextId}()$
$Meta[TokenId_{NFT^U_{MV}}] \leftarrow (TokenId_{NFT^U_{MV}}, name, ec)$
$Creator[TokenId_{NFT^U_{MV}}] \leftarrow recover$
$\mathsf{SetURI}(TokenId_{NFT^U_{MV}}, URI_{base})$
$\mathsf{SoulboundMint}(Addr_U, TokenId_{NFT^U_{MV}})$
return NFT^U_{MV}

Algorithm 1 defines *SafeMint*, a secure procedure for issuing soulbound identity NFTs for authentication in federated metaverse environments, enforcing issuer-authorized minting, a strict one-identity-per-user policy, and permanent non-transferability.

The procedure computes a deterministic hash $h = \mathsf{Keccak256}(Addr_U \parallel name \parallel ec)$, binding the wallet address $Addr_U$ and an on-chain cryptographic commitment ec (a hash of $email \parallel nonce$) to off-chain data; $name$ is retained in plaintext for on-chain lookup and display, while privacy-sensitive attributes remain protected solely through ec. ECDSA recovery verifies that the signer corresponds to the issuing metaverse (MV), so every NFT is cryptographically bound to both its issuer and recipient, and only an authorized Identity Provider can issue credentials. Requests from an address already holding an identity NFT are rejected, enforcing one credential per wallet.

Upon success, a fresh token identifier $TokenId_{NFT^U_{MV}}$ is generated with non-sensitive metadata, while external metadata may be referenced via the ERC-721 token URI (URI_{base}, a deployment-specific IPFS or HTTPS endpoint), keeping authentication commitments on-chain. The credential is minted as a soulbound NFT permanently bound to $Addr_U$, with transfers and approvals disabled to prevent resale, delegation, or reassignment.

Algorithm 2 Cryptographic Revocation of Identity Token

Require: $Addr_U$, $TokenId_{NFT^U_{MV}}$
Ensure: Irreversible revocation of NFT^U_{MV}
if $\neg\mathsf{Exists}(TokenId_{NFT^U_{MV}})$ **then**
  return Abort
end if
$Addr'_U \leftarrow \mathsf{OwnerOf}(TokenId_{NFT^U_{MV}})$
if $Addr'_U \neq Addr_U$ **then**
  return Abort
end if
$\mathsf{Burn}(TokenId_{NFT^U_{MV}})$
$\mathsf{UpdateState}(TokenId_{NFT^U_{MV}})$
return $\perp$

Algorithm 2 defines a cryptographically enforced revocation procedure for soulbound NFT–based identity credentials, allowing the credential owner to permanently invalidate an issued authentication NFT NFT^U_{MV} (e.g., due to wallet compromise, credential expiration, or voluntary deactivation) without relying on centralized authorities. The algorithm verifies the token's existence via $\mathsf{Exists}(TokenId_{NFT^U_{MV}})$ and retrieves its owner via $\mathsf{OwnerOf}(TokenId_{NFT^U_{MV}})$; revocation proceeds only if the invoking address $Addr_U$ matches this owner, binding revocation authority to wallet ownership.

Upon authorization, the credential is irreversibly invalidated via $\mathsf{Burn}(TokenId_{NFT^U_{MV}})$ and the contract state is updated, so subsequent ownership verification fails in both standalone and federated authentication.

Algorithm 3 Governance Proposal for Quorum Update

Require: Member address $Addr_M$, proposed quorum q_{new}, a proposal description $desc$
Ensure: Activated governance proposal GP_i
if $\neg\mathsf{Member}(Addr_M) \vee q_{new} \notin [1,100]$ **then**
  return Abort
end if
$i \leftarrow \mathsf{NextProposalId}()$
$GP_i \leftarrow \langle \mathsf{Type}_{Quorum}, q_{new}, Addr_M, desc, t_0 \rangle$
$\mathsf{Activate}(GP_i)$
return GP_i

Algorithm 3 defines the on-chain creation of quorum update proposals within the federation governance framework; since quorum parameters directly influence collective decisions, proposal creation is restricted to authorized members. The algorithm verifies that the proposer $Addr_M$ is a registered member and that the proposed quorum value q_{new} lies within an admissible range ($q_{new} \in [1,100]$). Upon validation, a unique proposal GP_i is created on-chain, encoding the proposal type, q_{new}, $Addr_M$, description $desc$, and creation timestamp t_0, then activated for time-bounded voting. Enforcing membership authorization and parameter bounds ensures transparent, tamper-resistant quorum management, with updates applied only after supermajority approval.

Algorithm 4 Governance Voting and Execution Procedure

Require: Voter address $Addr_M$, proposal identifier GP_i, vote $v \in \{0,1\}$
Ensure: Deterministic execution of governance decision
if $\neg\mathsf{Member}(Addr_M)$ **then**
  return Abort
end if
if $\neg\mathsf{Active}(GP_i)$ **then**
  return Abort
end if
if $\mathsf{Voted}(Addr_M, GP_i)$ **then**
  return Abort
end if
if $\mathsf{Now} > t_{GP_i} + \Delta_{gov}$ **then**
  $\mathsf{Deactivate}(GP_i)$
  return Abort
end if
$\mathsf{RecordVote}(Addr_M, GP_i, v)$
if $\mathsf{TotalVotes}(GP_i) \geq \mathsf{SuperMajority}$ **then**
  $\mathsf{Deactivate}(GP_i)$
  if $\mathsf{YesVotes}(GP_i) > \mathsf{NoVotes}(GP_i)$ **then**
    $\mathsf{Execute}(GP_i)$
  end if
end if
return

Algorithm 4 specifies the voting and execution procedure for federation-level decisions across federated metaverses.

Each proposal GP_i is evaluated within a fixed voting window Δ_{gov} (currently 3 days, updatable via governance voting) and finalized only upon reaching a predefined supermajority, ensuring collective consensus for security-critical actions.

The procedure enforces voter eligibility by verifying that $Addr_M$ is a registered member, the proposal is active, and the voter has not previously voted. Freshness is ensured by comparing Now against the activation time t_{GP_i} and Δ_{gov}; expired proposals are automatically deactivated to prevent delayed or replayed influence. Valid votes $v \in \{0,1\}$ are recorded via RecordVote.

Once $\mathsf{TotalVotes}(GP_i) \geq \mathsf{SuperMajority}$, the proposal is finalized and executed only if $\mathsf{YesVotes}(GP_i) > \mathsf{NoVotes}(GP_i)$; approved proposals update governance parameters (e.g., quorum percentage) via deterministic smart-contract execution, ensuring transparent and auditable federation management.

B. Use-cases and protocol flow

This section presents protocol flows for the use cases, with messages denoted M1–Mn. Off-chain communication uses HTTPS; smart contract interaction uses secure JSON-RPC over HTTPS (RPC). Fresh nonces and challenge–response signatures ensure freshness, prevent replay, and cryptographically bind authentication to wallet ownership.

1) NFT-Metaverse Identity Registration

To access metaverses, a user must register and receive an NFT following the protocol in Table III, which involves a user U, a metaverse platform MV, and the token smart contract SC_{Token}. In M1, U submits a *registerReq* containing the required credentials and a nonce $N1$ to MV over HTTPS. Upon successful validation, MV signs the credentials ($SignedCredentials^{U}_{MV}$) with its private key K^{-1}_{MV} and returns them in *registerRes* (M2), confirming off-chain registration. To finalize identity binding, U invokes SC_{Token} with $NFTMintReq$ (M3), carrying $Addr_U$, *name*, *ec*, and the MV-issued signature as specified in Algorithm 1; the raw email is not part of the on-chain call. The contract verifies the request and mints a non-transferable identity NFT bound to U, returning $NFTMintRes$ (M4). Credentials are thus authenticated by the metaverse and immutably anchored on-chain.

TABLE III: NFT-Metaverse Identity Registration & Authentication Protocol.

Use-case	Steps	Description
Identity Registration	M1	$U \rightarrow MV$: [N1, *registerReq*]$_{\text{HTTPS}}$
	M2	$MV \rightarrow U$: [N1, *registerRes*]$_{\text{HTTPS}}$
	M3	$U \rightarrow SC_{Token}$: [N1, *NFTMintReq*]$_{\text{RPC}}$
	M4	$SC_{Token} \rightarrow U$: [*N1*,*NFTMintRes*]$_{RPC}$
Identity Authentication	M1	$U \rightarrow MV$: [N1, *serviceReq*]$_{\text{HTTPS}}$
	M2	$MV \rightarrow U$: [N2, *WalletAddressReq*]$_{\text{HTTPS}}$
	M3	$U \rightarrow MV$: [N2, *WalletAddressRes*]$_{\text{HTTPS}}$
	M4	$MV \rightarrow SC_{Token}$: [N3, *NFTReq*]$_{\text{RPC}}$
	M5	$SC_{Token} \rightarrow MV$: [N3, *NFTRes*]$_{\text{RPC}}$
	M6	$MV \rightarrow U$: [N5, *SignatureReq*]$_{\text{HTTPS}}$
	M7	$U \rightarrow MV$: [N5, *SignatureRes*]$_{\text{HTTPS}}$
	M8	$MV \rightarrow SC_{Token}$: [N6, *NFTMetadataReq*]$_{\text{RPC}}$
	M9	$SC_{Token} \rightarrow MV$: [N6, *NFTMetadataRes*]$_{\text{RPC}}$
	M10	$MV \rightarrow U$: [N1, *serviceRes*]$_{\text{HTTPS}}$

2) NFT-Metaverse Identity Authentication

User authentication for accessing a metaverse is achieved through the NFT, following the flow in Table III.

U submits a *serviceReq* with $UUID_i$, a unique identifier for the ith user, to MV over HTTPS (M1); MV then requests and receives the wallet address $Addr_U$ (M2–M3). Using this address, MV queries SC_{Token} via secure JSON-RPC for the identity NFT owned by U (M4–M5), which is displayed in the login interface (Figure 3b). To prove control of the selected NFT, MV issues a challenge via *SignatureReq*, which U signs with the private key corresponding to $Addr_U$ and returns as *SignatureRes* (M6–M7). Upon successful signature verification, MV retrieves the NFT's on-chain metadata from SC_{Token} ($NFTMetadataReq$, $NFTMetadataRes$; M8–M9) and validates ownership by confirming that the address recovered from the signature matches $Addr_U$. On success, MV returns *serviceRes* (M10), binding access to verifiable NFT ownership without exposing private keys. A confirmation screen (Figure 3c) indicates that authentication is complete and the user may enter the metaverse environment.

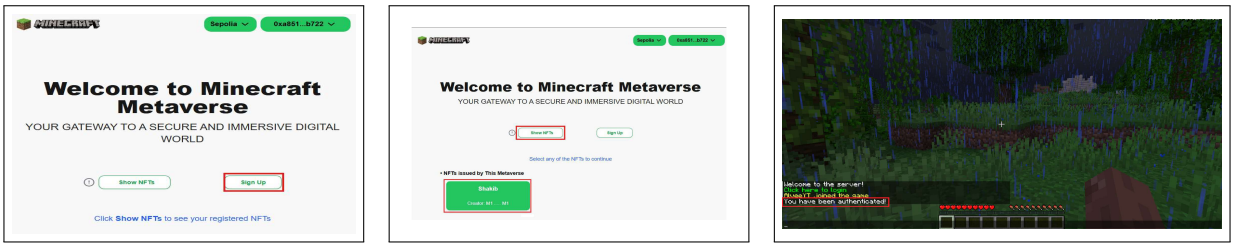
3) Metaverse Federation Membership Governance

Before participating in a federated metaverse ecosystem, metaverses must first be admitted to the federation through on-chain voting and may then be explicitly added to an SP's independent trust registry. This supports interoperable cross-metaverse authentication while preserving metaverse sovereignty over trust relationships and access control policies, with each metaverse selectively trusting only a subset of federation members. Each metaverse maintains its own smart contracts for credential issuance, authentication, and local trust management, while federation-wide membership and governance are coordinated through the governance contract SC_{Fed}.

TABLE IV: Federation Membership Onboarding & Revocation Protocol.

Use-case	Steps	Description
Membership Onboarding	M1	$MV \rightarrow SC_{Fed}$: [N1, *membershipReq*]$_{\text{RPC}}$
	M2	$MV_i \rightarrow SC_{Fed}$: [N2, *membershipVote*]$_{\text{RPC}}$
	M3	$SC_{Fed} \rightarrow MV$: [N3, *membershipRes*]$_{\text{RPC}}$
Membership Revocation	M1	$MV_i \rightarrow SC_{Fed}$: [N4, *governanceProposalReq*]$_{\text{RPC}}$
	M2	$MV_i \rightarrow SC_{Fed}$: [N5, *governanceVote*]$_{\text{RPC}}$
	M3	$SC_{Fed} \rightarrow MV_i$: [N6, *governanceProposalRes*]$_{\text{RPC}}$

The federation governance protocol uses on-chain quorum-based voting for membership onboarding, presented in Table IV. A candidate metaverse MV transmits *membershipReq* containing $websiteUrl$ to SC_{Fed} via JSON-RPC (M1); $websiteUrl$ serves as a verifiable identifier for review by existing members MV_i. Each MV_i evaluates the candidate and casts *membershipVote* with candidate address $Addr_M$ and approval $v \in \{0,1\}$ (reject/approve); SC_{Fed} records each vote and prevents duplicate voting by checking $Addr_i$, the wallet address of the ith voting metaverse (M2). Once the quorum threshold is reached within a 7-day voting window, SC_{Fed} tallies the votes and returns *membershipRes* with approval status v and *votingStatus* (M3). If approved, the new member is registered with $Addr_M$, $websiteUrl$, and $joinedAt$.



(a) Authentication page (b) NFT shown at login (c) In-game after login

Fig. 3: Metaverse Authentication Steps

Beyond onboarding, federation members collectively manage policy updates and member revocation through governance voting (Table IV), enforced by SC_{Fed}. MV_i initiates a proposal by transmitting *governanceProposalReq* with q_{new} (policy update or member removal) and description *desc* to SC_{Fed}, which validates membership status before creating the *GovernanceProposal* record (M1). Members review the proposal and cast *governanceVote* with proposal id GP_i and approval v; SC_{Fed} enforces a 3-day voting window (Δ_{gov}) and prevents double voting via the $hasVoted[Addr_M]$ mapping (M2). Once the supermajority threshold of 75% is reached within the voting window, SC_{Fed} finalizes the proposal and returns *governanceProposalRes* with GP_i, *executed* status, and *votingStatus*. If approved, changes such as updating q_{new} or removing members are applied automatically (M3).

V. User Study

This section describes the usability and user experience of the system focusing on ease of use, perceived security, and interaction overhead.

A. Study Design and Methodology

A usability evaluation is conducted with 25 students (undergraduate) recruited via convenience sampling. After a brief system demonstration, participants completed the authentication flow in a VR-enabled metaverse and answered usability questionnaires. Participant familiarity varied, with 64% reporting general blockchain knowledge and 36% prior wallet usage.

Following established practices [5], we employed the System Usability Scale (SUS), a standardized 10-item instrument scored from 0–100, where scores $\geq$ 68 indicate acceptable usability [3] and a 9-item custom UX survey using a 5-point Likert scale. The UX instrument assesses learnability, efficiency, satisfaction, and system integration, and is grounded in ISO 9241-11 [17], Nielsen's heuristics [28], and TAM [8]. All responses used a 5-point Likert scale (1 = Strongly Disagree, 5 = Strongly Agree). The study materials are publicly available online at[1].

B. Results and Analysis

The system achieved a mean SUS score of 69.4 $\pm$ 18.7 (median 72.5), placing it in the "good" usability range (Fig. 4); 13

[1]https://github.com/addshakib80/NFTAuth-user-study-questionnaires

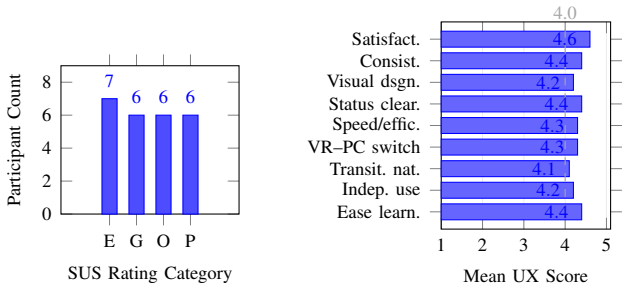


Fig. 4: (Left) SUS score distribution (N=25) across rating categories *Excellent (E), Good (G), OK (O), and Poor (P)*. (Right) Mean UX scores by question.

participants (52%) rated it good or excellent (SUS $\geq$68), with 7 (28%) exceeding 80.3. The custom UX survey scored consistently well (mean 4.34/5), highest for satisfaction (4.60), login clarity (4.44), consistency (4.44), and efficiency (4.36), with no significant difference by prior blockchain experience ($p > 0.5$), suggesting accessibility for non-experts. Participants praised clarity and metaverse integration but noted VR-to-desktop wallet switching as a limitation. The study is constrained by its single-metaverse setting and limited sample size ($N = 25$); future work will involve larger, more diverse populations across multiple platforms.

VI. Protocol Validation

We evaluated the security of the proposed NFT-based Registration and Authentication protocols using ProVerif [4], a state-of-the-art protocol verifier, focusing on the secrecy of private data and the authenticity of entities.

A. Secrecy Goals

Secrecy analysis in ProVerif determines which variables an adversary can access. We modeled sensitive protocol data as private variables which are *registerReq*, *registerRes*, *NFTMintRes*, *WalletAddressRes*, *NFTRes*, *SignatureRes*, *serviceRes* and *NFTMetadataRes*.

B. Authenticity Goals

Authenticity was verified using correspondence and injective correspondence assertions in ProVerif, ensuring correct event sequencing and one-to-one relationships for critical actions: Events for the identity registration flow (Table III):

- Event *U_BeginRegister*, *MV_IssueSignedCreds* and *U_EndRegister* (mark Steps M1–M2).

- Event *U_BeginMint*, *SCToken_Minted* and *U_EndMint* (trace Steps M3–M4).

Events for the identity authentication flow (Table III):

- Event *U_BeginService* (indicate Step M1).
- Event *MV_AskedWalletAddr* and *U_SentWalletAddrRes* (mark Step M2, M3).
- Event *MV_RequestedNFTs* and *SCToken_SentNFTs* (point Step M4, M5).
- Event *MV_AskedSignature* and *U_SentSignature* (trace Step M6, M7).
- Event *MV_RequestedMetadata* and *SCToken_SentMetadata* (point Step M8, M9).
- Event *MV_CompletedService* (indicate Step M10).

C. Results

ProVerif returns *true*, *false*, or *cannot be proven* for queries. All secrecy and authenticity queries returned *true*, confirming that sensitive data remains confidential and protocol events maintain integrity. Full ProVerif script and validation results of the identity registration and authentication protocol is available online at [2] for independent verification.

VII. Discussion

In this section, we discuss how the system satisfies the defined requirements and describe different aspects of the system.

A. Cost Analysis

We measured the gas cost of minting authentication NFTs on the Sepolia testnet using randomly generated usernames and emails (Table V). The results show stable gas usage across trials, with minting costs ranging from 1.84 to 2.39 at an average ETH price of $4.482 (September 19, 2025). These preliminary trials indicate feasibility at small scale; mainnet-scale and federation-level operation costs (e.g., governance voting) remain to be evaluated. Layer 2 solutions such as Arbitrum [29] and Polygon [34] can further reduce transaction costs at larger deployments.

TABLE V: Gas Cost Comparison of NFT Minting Method

Trial No	Gas Used (Units)	Gas Price (GWEI)	Total Cost (ETH)	Total Cost (USD)
1	251385	1.633477894	0.00041063	1.84
2	268545	1.983769691	0.00053273	2.39
3	251409	1.811745275	0.00045549	2.04

B. Threat Analysis

Our system uses ERC-721 NFTs as authentication tokens, with ownership verified via a signed challenge–response protocol. The Metaverse (MV) issues a fresh challenge, and the user (U) responds with an ECDSA signature ($Signature_U$) using their private key (K_U^{-1}), ensuring wallet ownership and mitigating spoofing ($T1$). Tampering ($T2$) is mitigated through issuer-signed credentials ($SignedCredentials_{MV}^{U}$) and the immutability of on-chain NFT state, enabling unauthorized modifications to be detected. Repudiation ($T3$) is mitigated by issuer-signed credentials and challenge–response verification of ownership. Sensitive information during minting and registration is protected via HTTPS (TLS), addressing information disclosure ($T4$). Replay attacks ($T7$) are prevented using nonces to ensure request freshness. DoS ($T5$) and elevation of privilege ($T6$) are partially mitigated: gas fees deter trivial DoS attempts, and revocation invalidates obsolete or compromised tokens, limiting unauthorized access. Governance manipulation remains bounded by the 75% supermajority and the per-metaverse local trust registry (Sections III-A, III-B), limiting the impact of an individually compromised federation member.

C. Comparative Analysis

Table VI compares representative NFT- and blockchain-based authentication and identity-management approaches against our framework across the nine criteria defined in the table footnote. The comparison is centered on *federated metaverse* support (C1), *NFT-based identity* (C2), *authentication* (C3), *protocol design* (C4), *implementation* (C5), *formal threat modelling* (C6), *formal protocol verification* (C7), *user study* (C8), and *cost analysis* (C9). Banaeian et al. [2], Hong et al. [16], Tsegaye et al. [40], Manzoor et al. [25], Kim et al. [20], and Madhwal et al. [22] mainly address single-platform identity, authentication, or access-control settings, and therefore do not provide federation-level trust governance. Ryu et al. [35] and Khan et al. [19] cover protocol and security aspects more strongly, but still rely on permissioned or CA-based trust assumptions and do not provide the full combination of federated interoperability, user evaluation, and deployable implementation. Stephenson et al. [39] offer useful usability insights for AR/VR authentication, but do not present an NFT-based system. In contrast, our framework integrates all nine criteria in a CA-independent architecture for interoperable authentication across autonomous metaverse platforms while preserving local trust control.

[2]https://github.com/addshakib80/NFTAuth-Protocol-Verification-files

D. Limitations and Future Work

Although the proposed NFT-based authentication mechanism is practically viable, several limitations remain. This work assumes real-world identity verification (e.g., email confirmation or KYC) is performed by the Metaverse prior to *registerReq*; the cryptographic binding and federation layer operate atop this assumed step. While sensitive attributes are excluded from on-chain storage, wallet addresses, NFT ownership, and transaction patterns remain publicly linkable, so our privacy guarantee covers attribute confidentiality rather than full unlinkability. The system also does not address identity recovery for lost keys (revocation itself requires the wallet key) or attribute updates, which currently require revocation and re-registration; external mechanisms such as social recovery or multi-signature schemes [23] could help. The governance model assumes a bounded number of malicious members, with collusion beyond the quorum threshold and sustained-participation incentive mechanisms left outside the current design.

Future work will focus on reducing metadata linkability through privacy-preserving techniques (e.g. selective disclosure, zero-knowledge proofs), improving VR-native wallet integration, cross-chain and layer-2 interoperability, enabling NFT-based identities to be securely verified across heterogeneous blockchain ecosystems.

VIII. Conclusion

The metaverse introduces identity and access management requirements that password-based, centralized authentication mechanisms cannot adequately address. This work presents a secure NFT-based authentication for federated metaverses that leverages blockchain immutability, smart contracts, and cryptographic primitives to provide decentralized, verifiable, and user-controlled authentication using non-transferable, soulbound-style NFTs. Unlike existing NFT-based approaches that primarily focus on single-platform authentication or rely on centralized identity providers, the proposed framework enables interoperable authentication across autonomous metaverse platforms through a CA-independent, federated architecture with on-chain governance and trust registries. In addition, the system incorporates privacy-aware identity representation and user-controlled credential issuance and revocation through smart-contract-enforced mechanisms. An Ethereum-based proof-of-concept demonstrates practical feasibility, while formal verification using ProVerif and an initial user study indicate that the system satisfies key security properties and shows promising usability. Overall, this work establishes a concrete foundation for secure, interoperable, and reusable token-based authentication in federated metaverse environments.

References

[1] I. Alom, R. M. Eshita, A. Ibna Harun, M. S. Ferdous, M. Kamrul Bashar Shuhan, M. J. M. Chowdhury, and M. Shahidur Rahman. Dynamic management of identity federations using blockchain. In *2021 IEEE International Conference on Blockchain and Cryptocurrency (ICBC)*, pp. 1–9, May 2021. doi: 10.1109/ICBC51069.2021.9461128

[2] S. Banaeian Far and S. M. Hosseini Bamakan. Nft-based identity management in metaverses: challenges and opportunities. *SN Applied Sciences*, 5(10):260, 2023. doi: 10.1007/s42452-023-05487-5

[3] A. Bangor, P. T. Kortum, and J. T. Miller. An empirical evaluation of the system usability scale. *International Journal of Human–Computer Interaction*, 24(6):574–594, 2008.

[4] B. Blanchet, B. Smyth, V. Cheval, and M. Sylvestre. Proverif 2.00: automatic cryptographic protocol verifier, user manual and tutorial. *Version from*, pp. 05–16, 2018.

[5] J. Brooke. Sus: a 'quick and dirty' usability scale. In *Usability Evaluation in Industry*, 1996.

[6] V. Buterin, P. Ohlhaver, and E. G. Weyl. Decentralized society: Finding web3's soul. *arXiv preprint arXiv:2203.15869*, 2022.

TABLE VI: Comparative analysis of existing works and our proposal

Paper	*C*1	*C*2	*C*3	*C*4	*C*5	*C*6	*C*7	*C*8	*C*9
Banaeian et al. [2]	○	● (Ethereum)	◐	○	○	○	○	○	○
Manzoor et al. [25]	○	● (Custom)	● (PoS-based)	◐	●	○	○	○	○
Hong et al. [16]	○	● (EOG NFT)	● (Biometric)	●	●	◐	○	○	○
Tsegaye et al. [40]	○	● (Custom)	● (Product)	●	●	○	○	○	○
Kim et al. [20]	○	● (SBT)	● (DID+zkSnark)	●	●	◐	○	○	◐
Azzaoui et al. [9]	○	● (QNFT)	● (ECC signature)	◐	○	○	○	○	○
Stephenson et al. [39]	○	○	○ (Survey)	○	○	◐	○	●	○
Khan et al. [19]	○	● (Ethereum)	● (ECC-based)	●	○	◐	● (AVISPA)	○	○
RYU et al. [35]	○	○	● (biometric)	●	○	● (Dolev-Yao, Canetti-Krawczyk)	● (BAN Logic, AVISPA)	○	●
Madhwal et al. [22]	○	● (ERC-721)	● (SBT)	◐	●	○	○	○	●
Our Work	●	● (ERC-721)	● (SBT)	●	●	● (STRIDE, Dolev-Yao)	● (ProVerif)	●	●

Legend: ● = Complete, ◐ = Partial, ○ = Not addressed. **Criteria:** C1=Federated Auth., C2=NFT Identity, C3=Auth. Mechanism, C4=Protocol Spec., C5=Implementation, C6=Threat Modeling, C7=Formal Verification, C8=User Study, C9=Cost Analysis.

[7] L. R. Christensen and A. Robinson. The potential global economic impact of the metaverse. Technical report, Analysis Group, 2022.

[8] F. D. Davis. Perceived usefulness, perceived ease of use, and user acceptance of information technology. *MIS Quarterly*, 13(3):319–340, 1989.

[9] A. El Azzaoui and J. Kim. Qnft: A post-quantum non-fungible tokens for secure metaverse environment. *Journal of Information Processing Systems*, 20(2):273–283, 2024.

[10] W. Entriken, D. Shirley, J. Evans, and N. Sachs. Eip-5192: Minimal soulbound nfts. Ethereum Improvement Proposal, 2022. https://eips.ethereum.org/EIPS/eip-5192.

[11] Y. K. D. et al. Metaverse beyond the hype: Multidisciplinary perspectives on emerging challenges, opportunities, and agenda for research, practice and policy. *International Journal of Information Management*, 66:102542, 2022.

[12] Ethereum Foundation. Ethereum. https://ethereum.org/. Accessed: 14-09-2025.

[13] Ethereum Foundation. Solidity programming language. https://docs.soliditylang.org/, 2025. Version 0.8, accessed: 14-09-2025.

[14] M. S. Ferdous and R. Poet. Analysing attribute aggregation models in federated identity management. In *Proceedings of the 6th International Conference on Security of Information and Networks*, SIN '13, p. 181–188. Association for Computing Machinery, New York, NY, USA, 2013. doi: 10.1145/2523514.2526998

[15] A. Giaretta. Security and privacy in virtual reality: a literature survey. *Virtual Reality*, 29(1):10, 2024. doi: 10.1007/s10055-024-01079-9

[16] K. Hong and B. M. Lee. Ethereum-based user authentication model using eog data for a service provider. *Journal of Multimedia Information System*, 9:275–286, 12 2022.

[17] Ergonomics of human-system interaction – part 11: Usability: Definitions and concepts, 2018.

[18] D. Johnson, A. Menezes, and S. Vanstone. The elliptic curve digital signature algorithm (ecdsa). *Int. J. Inf. Secur.*, 1(1):36–63, Aug. 2001.

[19] W. Z. Khan, A. Siddiqa, F. Alanazi, and M. K. Khan. Nft-based digital identity authentication framework for the metaverse environments. *IEEE Transactions on Consumer Electronics*, 71(2):5699–5707, 2025.

[20] G. Kim and J. Ryou. Digital authentication system in avatar using did and sbt. *Mathematics*, 11:4387, 10 2023.

[21] K. Ko, T. Jeong, J. Woo, and J. W.-K. Hong. Survey on blockchain-based non-fungible tokens: History, technologies, standards, and open challenges. *International Journal of Network Management*, 34(1), 2024.

[22] Y. Madhwal, P. Chekriy, and Y. Yanovich. A blockchain-based access control architecture using non-transferable nfts and gas-efficient ipfs uri management. In *2025 IEEE International Conference on Blockchain (Blockchain)*, pp. 117–124, 2025. doi: 10.1109/Blockchain67634.2025.00025

[23] E. V. Mangipudi, P. Chatzigiannis, K. Chalkias, A. Kate, M. Minaei, and M. Mondal. Web3 recovery mechanisms and user preferences. *Cryptology ePrint Archive*, 2025.

[24] A. Manoharan, A. Sriskantharajah, K. Herath, K. Guruge, and L. Yasakethu. Metahuman based phishing attacks in the metaverse realm: Awareness for cyber security education. *Education and Information Technologies*, 30:12939–12965, 01 2025.

[25] K. Manzoor, U. Noor, and Z. Rashid. Nft-based blockchain-oriented security framework for metaverse applications, 2023.

[26] S. Nakamoto. Bitcoin: A peer-to-peer electronic cash system. *Cryptography Mailing list at https://metzdowd.com*, 03 2009.

[27] A. Nanzatov, L. Peña-Castillo, and O. Meruvia-Pastor. Nrxr-id: Two-factor authentication (2fa) in vr using near-range extended reality and smartphones, 2025.

[28] J. Nielsen. *Usability Engineering*. Morgan Kaufmann Publishers Inc., San Francisco, CA, USA, 1994.

[29] Offchain Labs. Arbitrum: Ethereum layer 2 scaling solution. https://arbitrum.io/, 2025. Accessed: 2025-10-04.

[30] OpenJS Foundation. Node.js. https://nodejs.org/, 2025. Version accessed: 14-09-2025.

[31] OpenZeppelin Team. Signaturechecker utility. https://docs.openzeppelin.com/contracts/4.x/api/utils\#SignatureChecker, 2025. Accessed: 15-09-2025.

[32] PaperMC. Paper-archive: Version 1.21.1. https://github.com/PaperMC/Paper-archive/tree/ver/1.21.1, 2025. Accessed: 15-09-2025.

[33] S. Patwe and S. B. Mane. Blockchain-enabled secure and interoperable authentication scheme for metaverse environments. *Future Internet*, 16(5), 2024. doi: 10.3390/fi16050166

[34] Polygon Labs. Polygon: Scalable blockchain infrastructure for ethereum. https://polygon.technology/, 2025. Accessed: 2025-10-04.

[35] J. Ryu, S. Son, J. Lee, Y. Park, and Y. Park. Design of secure mutual authentication scheme for metaverse environments using blockchain. *IEEE Access*, 10:98944–98958, 2022.

[36] A. Shostack. *Threat Modeling: Designing for Security*. Wiley, 2014.

[37] M. K. B. Shuhan, S. M. Hasnayeen, T. K. Das, M. N. Sakib, and M. S. Ferdous. Decentralised identity federations using blockchain. *International Journal of Information Security*, 23(4):2759–2782, 2024. doi: 10.1007/s10207-024-00864-6

[38] Spark Technologies. Sparkjava. https://sparkjava.com/, 2025. Version 2.9.3, accessed: 14-09-2025.

[39] S. Stephenson, B. Pal, S. Fan, E. Fernandes, Y. Zhao, and R. Chatterjee. Sok: Authentication in augmented and virtual reality. In *2022 IEEE Symposium on Security and Privacy (SP)*, pp. 267–284, 2022.

[40] B. Z. Tsegaye, D. K. Mekonnen, M. H. Sahle, N. G. Fisseha, and K. S. Arvind. Tracing authenticity: A blockchain and nft-based approach to product verification. 2023.

[41] Vercel Inc. Next.js. https://nextjs.org/, 2025. Version accessed: 14-09-2025.

[42] wagmi.sh. wagmi.js: React hooks for ethereum. https://wagmi.sh/, 2025. Version 2.14.8, accessed: 14-09-2025.

[43] Y. Wang, Z. Su, N. Zhang, R. Xing, D. Liu, T. H. Luan, and X. Shen. A survey on metaverse: Fundamentals, security, and privacy. *IEEE Communications Surveys & Tutorials*, 25(1):319–352, 2023. doi: 10.1109/comst.2022.3202047

[44] web3j Team. web3j: Java library for ethereum. [Online]. Available: https://web3j.io/, 2025. Version accessed: 5.0.0, accessed: 15-09-2025.

[45] K. Yong, N. Katuk, and N. H. Zakaria. Authentication mechanisms for mobile learning applications: a usability study. *International Journal of Engineering and Technology(UAE)*, 7:193–198, 11 2018.

[46] Z. Zheng, S. Xie, H. Dai, X. Chen, and H. Wang. An overview of blockchain technology: Architecture, consensus, and future trends. In *IEEE BigData Congress*, pp. 557–564, 2017.